Kerberos Bronze Bit Attack (CVE-2020-17049) Scenarios to Potentially Compromise Active Directory

trimarcsecurity.com/hub-post/leveraging-the-kerberos-bronze-bit-attack-cve-2020-17049-scenarios-to-compromise-active-directory

Sean Metcalf December 10, 2020

Updated: Dec 13, 2024

Introduction & Attack Overview

Jake Karnes (@jakekarnes42) with NetSPI published 3 articles (that's right 3!) describing a new attack against Microsoft's Kerberos implementation in Active Directory. He posted an Overview article, describing how the attack works, an Attack article on practical exploitation, and if you need further background on Kerberos, a Theory article.

This article attempts to summarize the key details of the attack and provide some expanded information and potential attack scenarios, including how Active Directory could be compromised leveraging this attack method.

Kerberos Bronze Bit Attack TLDR:

If an attacker is able to gain knowledge of a service account's password hash (which has constrained delegation or resource-based constrained delegation configured), this exploit enables the attacker to impersonate any user (even those protected from delegation with Protected Users or "account is sensitive and cannot be delegated") when connecting to a service the service account is allowed to delegate to.

The Kerberos Bronze Bit Attack exploit has been incorporated into the Impacket framework already, so attackers are able to perform this attack today. And patching this issue is not as simple as just installing the patch on all Domain Controllers (more on that in the next section).

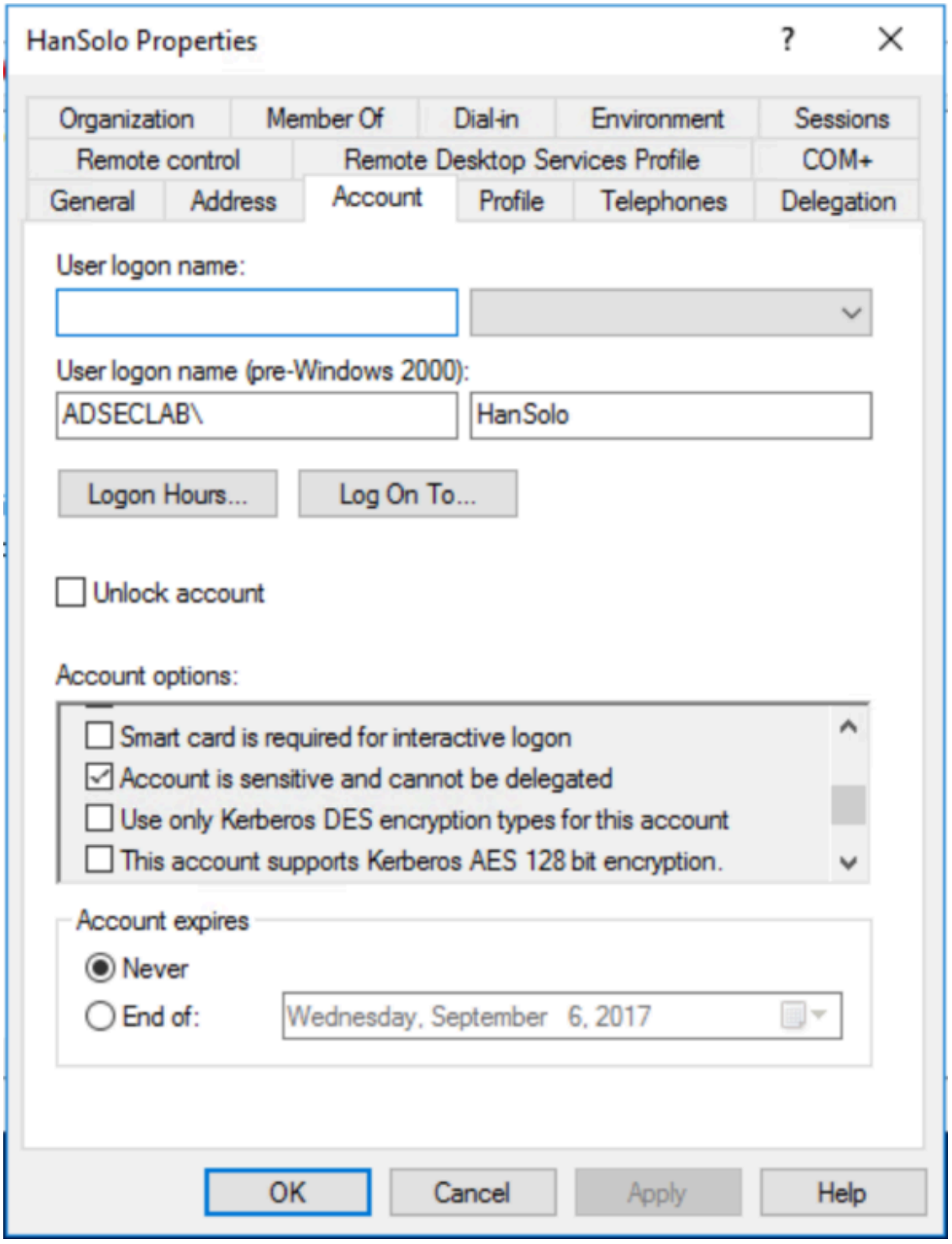
Key Attack Detail & Kerberos Delegation Overview

There are 2 key details to this attack (as described by Jake Karnes):

1. *An attacker can impersonate users which are not allowed to be delegated. This includes members of the Protected Users group and any other users explicitly configured as "sensitive and cannot be delegated."*

2. *An attacker can launch the attack from a service which is not allowed to perform the authentication protocol transition. This means that if the service is configured without the "TrustedToAuthForDelegation" property (shown as "Trust this user for delegation to specified services only – Use Kerberos only" in the AD GUI), the attacker can use the exploit to obtain tickets as if the "TrustedToAuthForDelegation" property were set (shown as "Trust this user for delegation to specified services only – Use any authentication protocol" in the AD GUI).*

Detail item #1 above notes that even when AD accounts are explicitly protected from delegation attacks, the Bronze Bit Attack can still effectively target and impersonate them. This is a big deal since the best mitigation for Kerberos Delegation attacks has been configuring admin accounts to not allow delegation, either by adding to the Protected Users group or setting the "account is sensitive and cannot be delegated" as shown in the screenshot below.



We can easily identify accounts configured to protect against Kerberos delegation attacks using PowerShell.

Detail item #2 is probably the most interesting part of this attack. But before describing why, let's take a moment to review Kerberos Delegation and how it works.

Kerberos Delegation Types:

- **Unconstrained:** Impersonate users connecting to service to ANY Kerberos service.

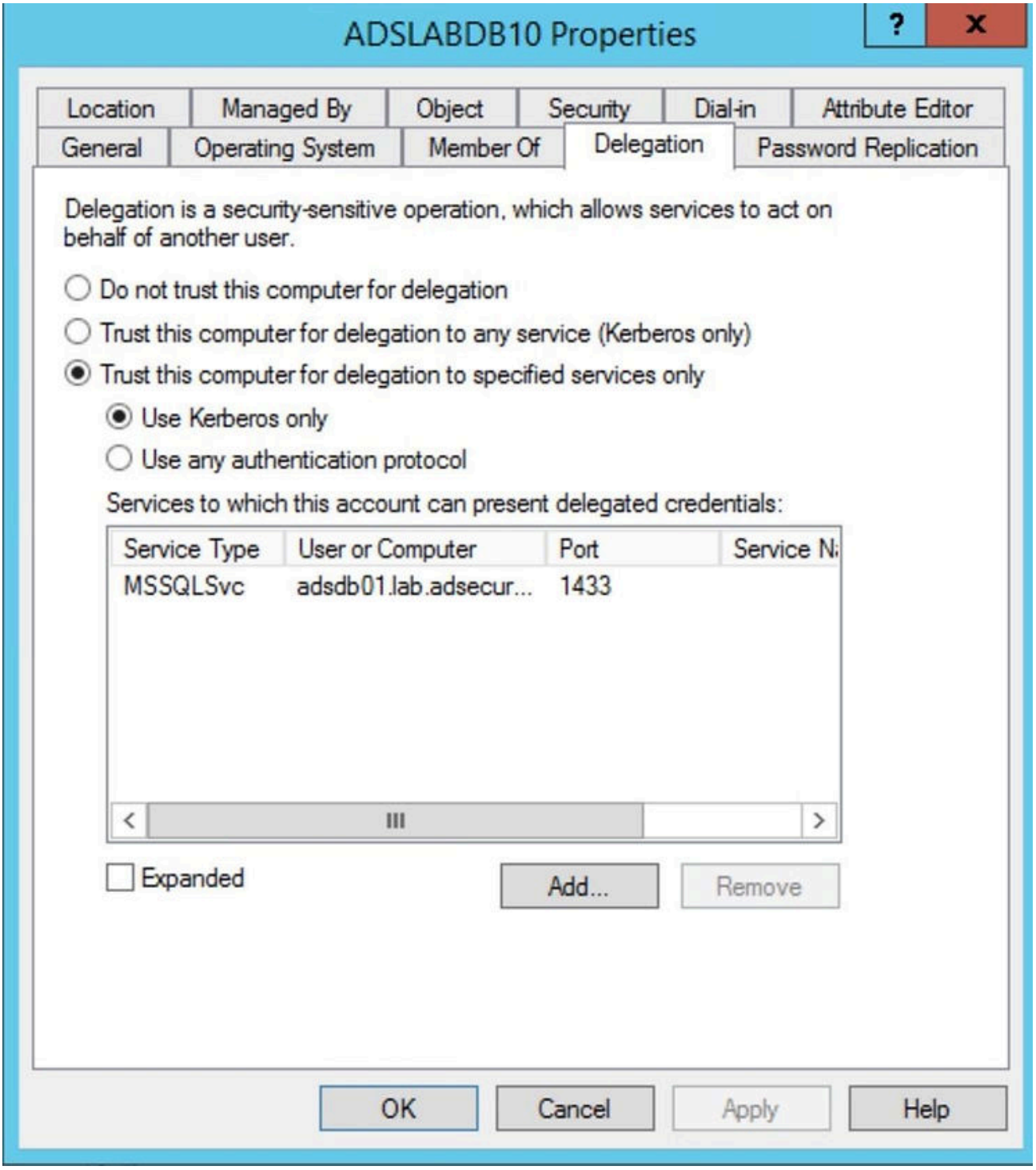
- **Constrained:** Impersonate authenticated users connecting to service to SPECIFIC Kerberos services on servers.
- **Constrained with Protocol Transition:** Impersonate any user (without prior authentication) to SPECIFIC Kerberos services on servers.
- **Resource-based Constrained Delegation:** Enables delegation configured on the resource instead of the account.

Kerberos Delegation has two primary options: Kerberos Unconstrained Delegation (KUD) and Kerberos Constrained Delegation (KCD). I spoke and blogged about the dangers of Kerberos Unconstrained Delegation in 2015 (at BlackHat & DEFCON).

Unconstrained delegation means that the account configured with this type of delegation can effectively impersonate a user who has authenticated to the service to any Kerberos service in the AD forest (and potentially in other forests as well). Compromising an account with unconstrained delegation means effectively compromise of all accounts that have authenticated to its associated service.

Constrained delegation means that the account configured with this type of delegation can impersonate a user who has authenticated to the service to specifically defined server services as defined in the constrained delegation settings on that account. In the screenshot below, the computer account is allowed to impersonate users only when connecting to the MSSQLSvc service on the computer ADSDB01.lab.adsecurity.org on port 1433 (this is related to the Kerberos Service Principal Name (SPN) associated with this service on the computer account). The account allowed to delegate will not be able to get delegation tickets to impersonate users to other services on the network.

Kerberos Constrained Delegation (Kerberos Only)

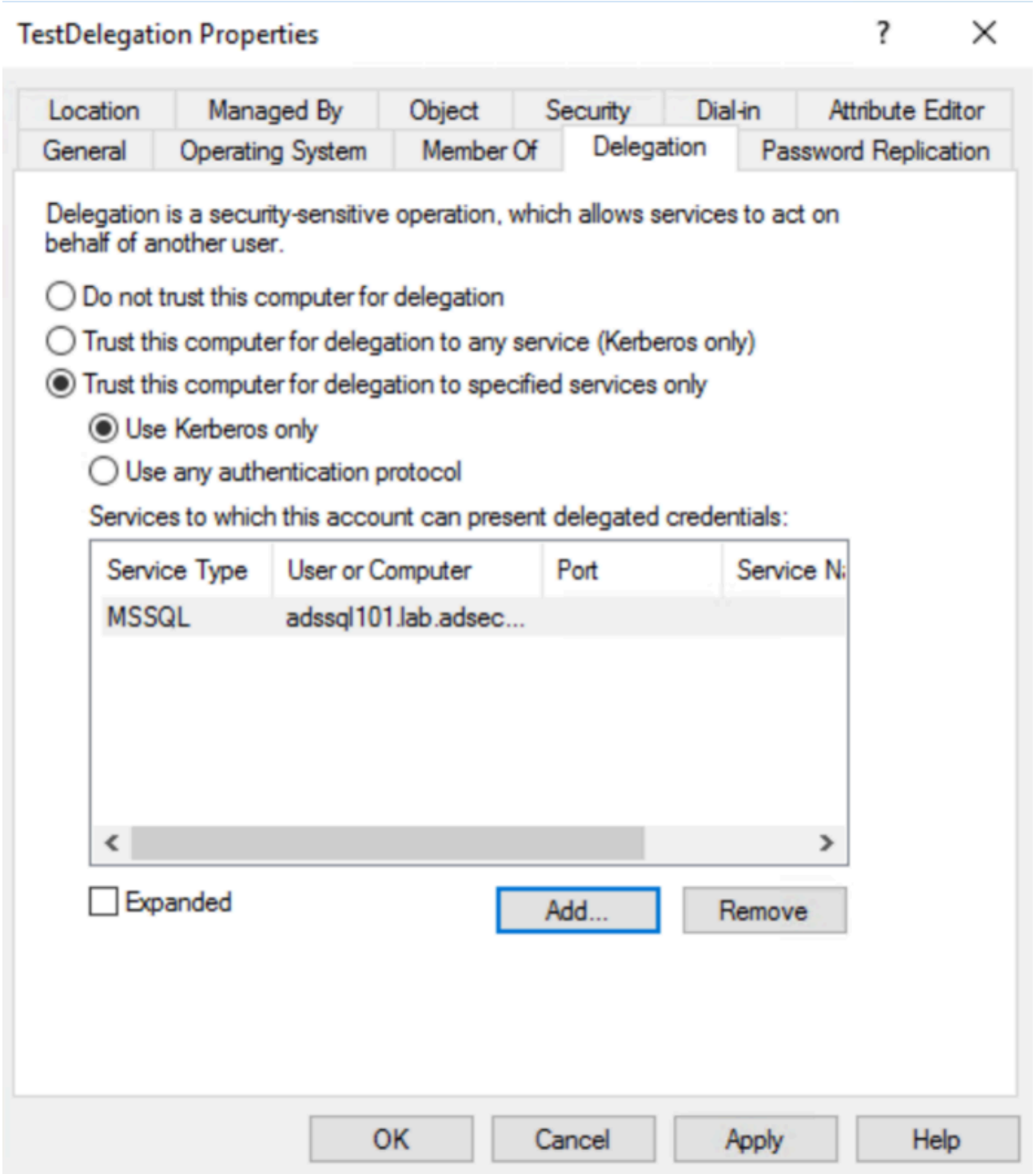


There are 2 options when configuring Kerberos Delegation: 1) Kerberos authentication only (S4U2proxy) and 2) Use any authentication protocol (S4U2self aka “Protocol Transition”).

The Kerberos only setting is the most common that Trimarc sees in customer environments and this means that when a user authenticates to the service account (typically on a web server) that is configured for constrained delegation, the service account requests a delegation ticket from a Domain Controller to the service it needs to impersonate the user and connect to (typically a database server). If you take anything away from this paragraph it should be this: Constrained delegation with Kerberos

authentication means that the user must authenticate to the service (service account) first. Then the service requests & receives a delegation ticket for that user.

Kerberos Constrained Delegation (Kerberos Only)

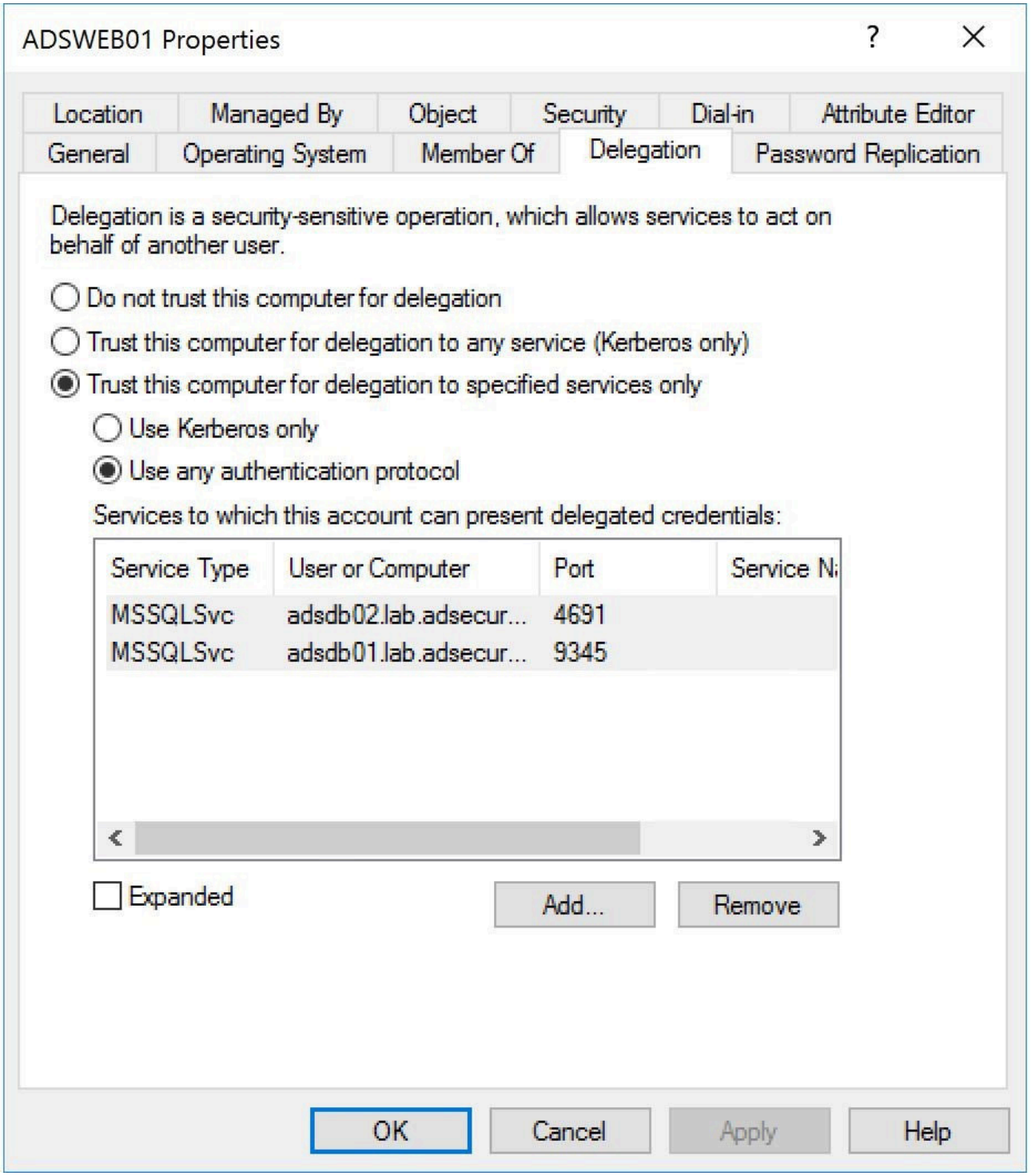


A delegation ticket provides the ability for the service account (configured to allow Kerberos delegation) to connect to the services on servers (specified in the Kerberos constrained delegation setting on the account) as the user. This is why I refer to Kerberos delegation as impersonation.

What makes the Kerberos Bronze Bit Attack so interesting and effective is that it can ignore this constrained Kerberos delegation setting (Kerberos Only) and leverage the 2nd method which is “use any authentication protocol” to get a Kerberos delegation ticket for any AD user with no prior authentication.

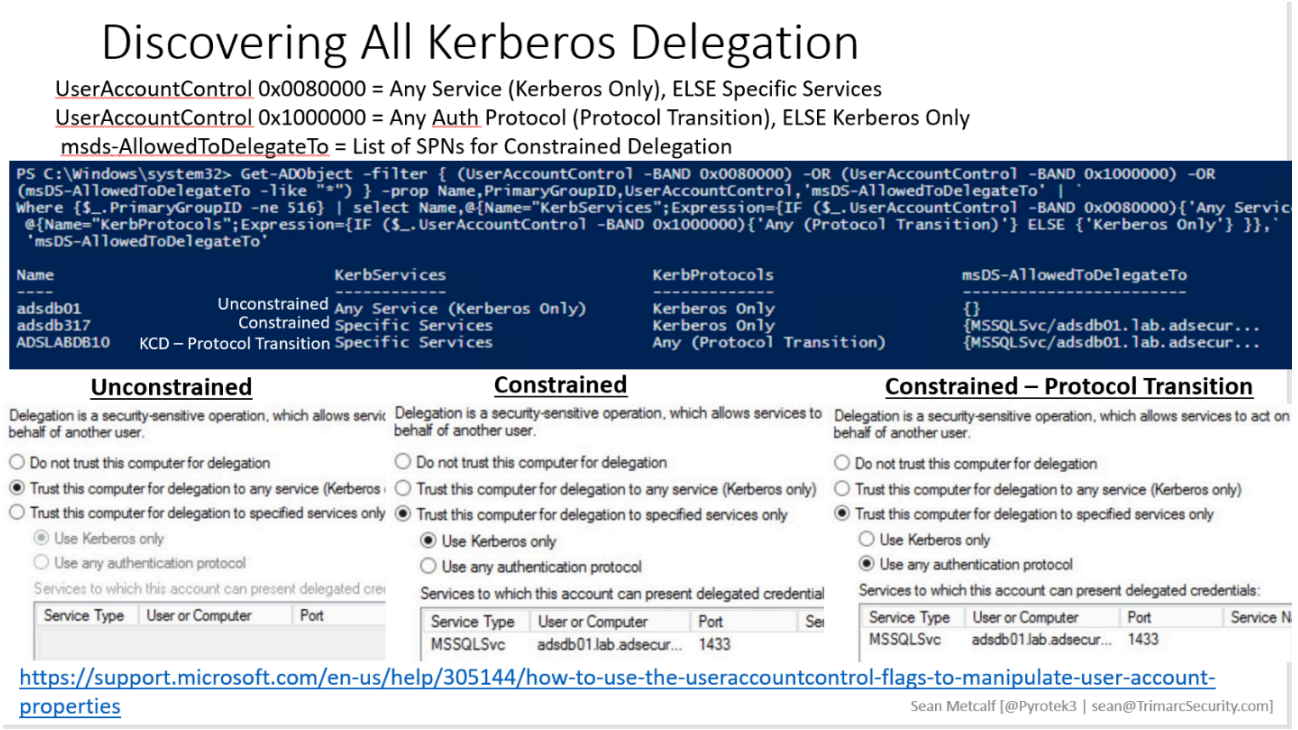
The constrained delegation setting “Use any authentication protocol” enables the service account to get a delegation ticket from a Domain Controller for any AD user simply by asking for it. I call this “Kerberos Magic”.

Kerberos Constrained Delegation (Use any authentication protocol)



This setting was implemented to support scenarios where a user authenticates to a service with a method that cannot easily be provided to a Domain Controller to prove authentication such as client certificate authentication. This means that the service does not need to prove prior authentication to get a delegation ticket for the user it is requesting, and the Domain Controller provides it. That's why I call this "Kerberos Magic". The service account can effectively create delegation tickets.

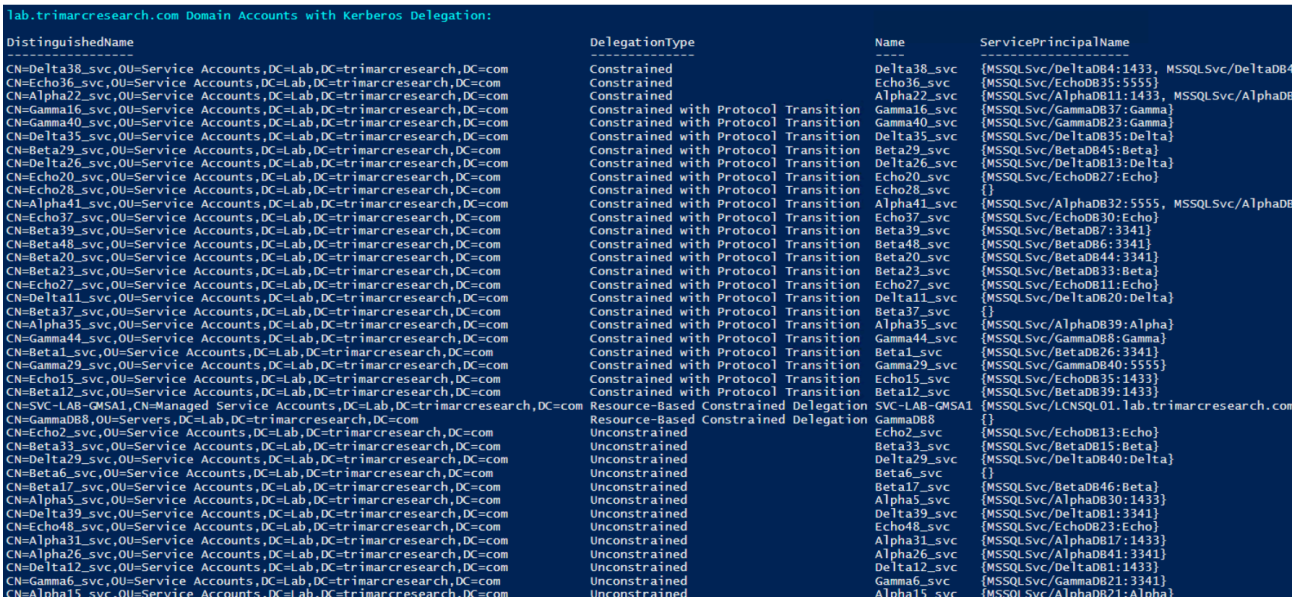
At SparkCon 2017, I presented on how to discover Kerberos Delegation:



Here's the PowerShell code for Kerberos Delegation discovery:

```
Get-ADObject -filter { ((UserAccountControl -BAND 0x0080000) -OR
(UserAccountControl -BAND 0x1000000) -OR (msDS-AllowedToDelegateTo -like '*') -OR
(msDS-AllowedToActOnBehalfOfOtherIdentity -like '*')) -AND (PrimaryGroupID -ne
'516') -AND (PrimaryGroupID -ne '521') } -prop
Name,ObjectClass,PrimaryGroupID,UserAccountControl,ServicePrincipalName,msDS-
AllowedToDelegateTo,msDS-AllowedToActOnBehalfOfOtherIdentity
```

Trimarc has also released a free PowerShell script which discovers Kerberos Delegation (in a single domain AD forest): https://www.hub.trimarcsecurity.com/post/securing-active-directory-performing-an-active-directory-security-review



```
lab.trimarcresearch.com Domain Accounts with Kerberos Delegation:

DistinguishedName                                                
```

If the PerformTicketSignature is set to “0” then Kerberos ticket signatures are disabled. Microsoft does not recommend this setting, though it’s an option. Don’t do this.

This registry key is planned to be set to “Enforcement” in the February 2021 patch cycle.

This means that Domain Controllers will likely be vulnerable in most Active Directory environments until February 2021 (and possibly longer if Microsoft delays the patch that configures enforcement).

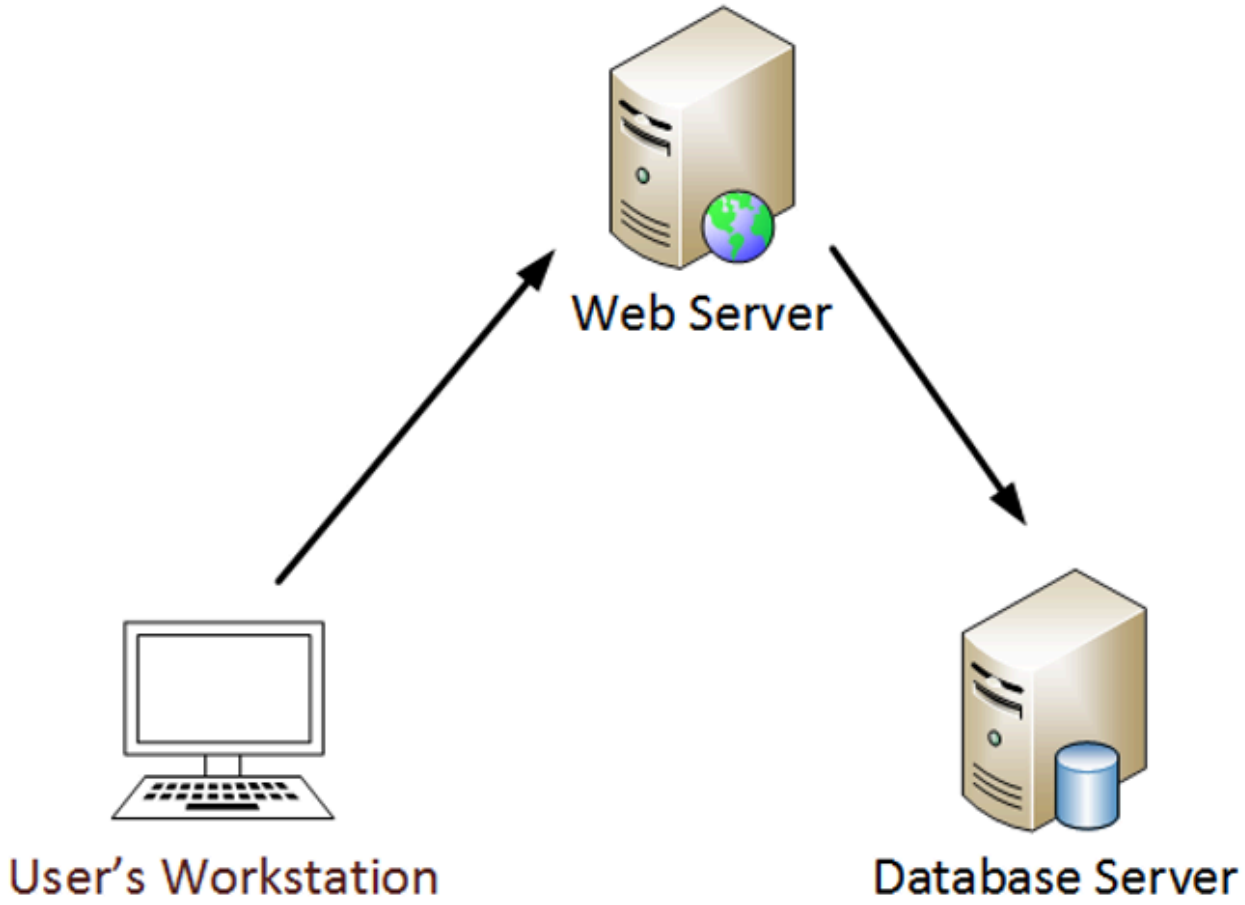
In order for Domain Controllers running Windows Server 2008 or Windows Server 2008 R2 to get this security update, the customer must have Extended Support Updates (ESU) as an additional license option. If the ESU key is not installed on the servers, the update will not install.

There really is no reason to continue to run Windows Server 2008/2008R2 on Domain Controllers, so updating the OS to a supported version is required if you don’t have ESU.

The Attack Scenario: Attacking InGen

The articles linked in the Introduction section above describe the attack. In this article, I create a scenario where the attacker targets the fictional company: InGen Technology.

InGen has a web application, “DinoDNA”, with access restricted to dinosaur lab researchers only. The back-end database for DinoDNA is hosted in InGen’s SQL database farm which is managed by the InGen Database Administrator team (Active Directory group “InGen DB Admins”). While InGen is great at cloning creatures from >60 million years ago, they aren’t so great at securing elements of their systems, despite “sparing no expense”. The DinoDNA service account is “svc_DinoDNA@ingentech.co” and it has a Kerberos Service Principal Name (SPN) set to “DINO/dinoweb.ingentech.co”. In order for users to authenticate to the DinoDNA application and have updates to the back-end SQL database show as being updated by the users (and not the DinoDNA account), Kerberos Delegation is configured. Kerberos Delegation is effectively impersonation and is a setting on an Active Directory user/computer account to provide the ability to impersonate users.



In this scenario, the svc_DinoDNA service account is configured with Constrained Delegation allowing it to impersonate users who authenticate to the service to then impersonate users when the DinoDNA needs to connect to the SQL DB on the SQL server farm (Constrained Delegation configured to allow delegation/impersonation from the svc_DinoDNA service account to MSSQLSvc on SQLDB01, SQLDB02, SQLDB03, & SQLDB04)

An attacker was able to get a foothold in the system by phishing users and tricking them into opening a malicious document. With this initial access, the attacker scanned the Active Directory environment and discovered the svc_DinoDNA service account. After performing some additional reconnaissance, the attacker realizes that gaining access to the DinoDNA application would provide access to proprietary data containing dinosaur DNA and core cloning functions. The attacker performs a Kerberoast attack against the svc_DinoDNA service account and is able to crack the password fairly easily since it is a common keyboard combination ("1qaz@wsx") often referred to "Password Walking". With this password identified, the attacker creates the associated password hash and leverages this in combination with the Kerberos Bronze Bit attack in order to get a valid service ticket to the DinoDNA SQL database as a SQL Admin account (dnedry-dba who is a member of the InGen DB Admins group). With this valid service ticket, the attacker is able to access the DinoDNA SQL database with full admin rights.

Attack Summary:

1. Attacker has a foothold in the InGen corporate network.
2. Attacker gains knowledge of the password hash for the DinoDNA service account by kerberoasting the account.
3. The DinoDNA service account is configured with constrained delegation in order to allow the DinoDNA webserver to impersonate users when connecting to the back-end SQL database that stores the DinoDNA application data.
4. The attacker targets one of the SQL database admins (dnedry-dba) in the AD environment for this attack, even if they are a member of the "Protected Users" group or has "Account is sensitive and cannot be delegated" set. These protections are bypassed by this attack, so are irrelevant to the attacker.
5. Attack code leverages S4U2self and S4U2proxy protocols to obtain a service ticket to SQL for the dnedry-dba account using the service account's password hash.
6. The attack code then flips the "Forwardable bit to 1 on the service ticket.
7. This modified service ticket is used in the S4U2proxy protocol to get a service ticket for the SQL service on one of the SQL database servers as the dnedry-dba account.
8. With this final, valid service ticket, the attacker can access the SQL database as dnedry-dba.

Jake Karnes notes in his published article that the attack is possible because the forwardable flag is only protected by the ticket encryption which uses the service account's password hash. Knowledge of this enables flipping this bit value.

Leveraging the Bronze Bit Attack to Compromise Active Directory

While discussing the Bronze Bit Attack within Trimarc, we were talking about worse case scenarios. Compromising Active Directory with this attack definitely falls under worse case scenario. Trimarc has identified the following configuration in about 5% of customer Active Directory Security Assessments (ADSAs), so this is not a hypothetical scenario.

Kerberos Delegation configuration on Active Directory accounts is limited to Domain Admins by default; however, the right to set Kerberos Delegation on AD accounts can be delegated. This requires setting the User Right Assignment "Enable computer and user accounts to be trusted for delegation". Additionally, the account that receives this right also requires write access to "account control flags" on the targeted account.

Continuing the InGen fictional story, they have an Active Directory environment where the InGen AD Admins have delegated the User Right Assignment "Enable computer and user accounts to be trusted for delegation" to the AD group "InGen Server Admins". This group also has Full Control (GenericAll) rights on the "Enterprise Applications" OU. With this

combination of rights, any member of the InGen Server Admins group can configure Kerberos Delegation on any account in the Enterprise Applications OU. The attacker identifies that there are several user accounts in the “InGen Server Admins” group and spearphishes them and this attack is successful for one of them. The attacker then creates a new account in the Enterprise Applications OU or modifies an existing account. Either way, the attacker configures the LDAP service on a Domain Controller as an additional allowed configuration for Kerberos Constrained Delegation on the account. Once this is set, the attacker leverages the Kerberos Bronze Bit attack to impersonate a Domain Admin in a service ticket valid for the LDAP service on a DC. Once the attacker gets the valid Kerberos service ticket, they are able to run Mimikatz DCSync against the Domain Controller to pull the password hashes for all Domain Admins, Domain Controller computer accounts, and KRBTGT. Now the attacker owns Active Directory.

It’s important to note that not many AD environments have delegated the ability to configure Kerberos Delegation, so this seems like an extreme example. Trimarc has identified that about 40% of customers have at least 1 account that is not an Active Directory administrator account that has the ability to modify a group policy linked to the Domain Controllers OU. Compromise of this account would enable the attacker to configure an AD group with the ability to set Kerberos Delegation. You may ask why do that when you could run code on a DC or update the AD Administrators group membership? The answer is that there is no good detection for the Kerberos Bronze Bit attack currently, so performing this action would likely not be noticed.

Key takeaways to leveraging Kerberos Bronze Bit to compromise Active Directory through Kerberos Constrained Delegation:

- Attacker gains knowledge of an AD user account (could be an existing service account).
- Attacker has compromised an account that is able to configure Kerberos delegation on an AD user account the attacker has the password for (Domain Controller User Rights Assignment + write access to the AD account’s “account control flags”).
- Attacker configures Kerberos Constrained Delegation on the AD account so the account can delegate to the LDAP service on one/many/all Domain Controllers.
- Attacker runs the Kerberos Bronze Bit attack code to get a delegation ticket for an Active Directory admin, even if that account is a member of Protected Users or has “account is sensitive and cannot be delegated” set.
- Attacker uses the new delegation ticket for the AD admin to compromise AD

There is a second way that the Kerberos Bronze Bit Attack could be leveraged to compromise Active Directory and that’s through Resource-based Constrained Delegation.

Resource-based Kerberos Constrained Delegation (RBKCD) where the resource itself determines what accounts can delegate to itself. This means that if an attacker has Write (modify) access to the account ("RBKCD-target-account"), the attacker can add an attacker-controlled account to the PrincipalsAllowedToDelegateToAccount (attribute msds-AllowedToActOnBehalfOfOtherIdentity) list set on the RBKCD-target-account. This enables RBKCD on the RBKCD-target-account and provides constrained delegation from the attacker controlled account to the RBKCD-target-account.

The attacker controlled account could even be a newly created computer account using PowerMad if AD is configured with the default setting which allows Authenticated Users the ability to join computers to the domain).

An attacker could compromise Active Directory with the Bronze Bit Attack is if the attacker has compromised an account with write (modify) access to a Domain Controller computer account and has compromised another AD account (JoeUser). With this access, the attacker can add the JoeUser account to the PrincipalsAllowedToDelegateToAccount list on the Domain Controller computer account. Since the attacker controls the JoeUser account and has knowledge of the password, the attacker could leverage the Kerberos Bronze Bit attack to connect to the Domain Controller's service (say LDAP) as any AD user, such as an AD admin account.

Trimarc identified that about 15% of customers have permissions on Domain Controllers (or the Domain Controllers OU) that would allow an account that is not an Active Directory admin account to perform this attack.

Key takeaways to leveraging Kerberos Bronze Bit to compromise Active Directory through Resource-Based Kerberos Constrained Delegation:

- Attacker gains knowledge of an AD user account (could be an existing service account) or creates a new computer account in AD.
- Attacker has compromised an account that has write access to a Domain Controller computer account or the ability to set permissions on computer objects at the domain or Domain Controller OU level.
- The attacker can add the JoeUser account to the PrincipalsAllowedToDelegateToAccount list on the Domain Controller computer account.
- Attacker runs the Kerberos Bronze Bit attack code to get a delegation ticket for an Active Directory admin, even if that account is a member of Protected Users or has "account is sensitive and cannot be delegated" set.
- Attacker uses the new delegation ticket for the AD admin to compromise AD.

Note that this attack method is possible without leveraging the Kerberos Bronze Bit Attack provided that accounts with AD admin rights are not protected against delegation. The Kerberos Bronze Bit Attack enables us to bypass these protections and use any AD admin account.

Trimarc recommends the following review to ensure that compromising Active Directory with the Kerberos Bronze Bit is mitigated:

- Ensure only AD admins are able to configure Kerberos Delegation in AD domains (default setting) by reviewing all Domain Controller group policy User Right Assignment setting “Enable computer and user accounts to be trusted for delegation”. Remove any additional accounts/groups that are configured with this right.
- Review the permissions on the Domain and Domain Controllers OU to ensure that no additional permissions are granted that allow accounts that are not AD admins the ability to change permissions (WriteDACL/WriteOwner/GenericAll) or the ability to set Resource-Based Kerberos Constrained Delegation (Write access) on Domain Controllers. Scanning Domain Controllers directly for these permissions is advised to determine if this is an issue.

You could also reach out to us to have Trimarc perform an Active Directory Security Assessment (ADSA) where we perform these reviews as part of the engagement. :)

Detection

Detection of this attack is difficult since the Kerberos service ticket that is ultimately used is a valid ticket. It mat be possible to look for tickets marked “forwardable” that are associated with accounts that are members of “Protected Users” (assuming all admin accounts are members of this group) and/or another custom AD group that contains accounts protected configured to block Kerberos Delegation since they should not allow delegation.

Microsoft Patch Process

Microsoft released the patch on December 8, 2020 for this issue, though in order to enforce the KDC behavior change where Kerberos tickets are signed to prevent this attack from working, a registry key must be set. Microsoft refers to this change as “Enforcement”. Microsoft is planning to set the registry key to Enforcement mode in February 2021.

Relevant screenshots from the following article are shown below.

Microsoft issue summary:

A security feature bypass vulnerability exists in the way the Key Distribution Center (KDC) determines whether a Kerberos service ticket can be used for delegation through Kerberos Constrained Delegation (KCD). To exploit the vulnerability, a compromised service that is

configured to use KCD could tamper with a Kerberos service ticket that is not valid for delegation to force the KDC to accept it. The Windows update addresses this vulnerability by changing how the KDC validates Kerberos service tickets used with KCD.
https://support.microsoft.com/en-us/help/4598347/managing-deployment-of-kerberos-s4u-changes-for-cve-2020-17049

Take Action

To protect your environment and prevent outages, you must do the following:

1. Update all devices that host the Active Directory domain controller role by installing the December 8, 2020 Windows update or a later Windows update. Be aware that installing the Windows update does not fully mitigate the security vulnerability. You must perform Step 2.
2. Enable **Enforcement** mode on all Active Directory domain controllers. Starting with the February 9, 2021 update, **Enforcement** mode will be enabled on all Windows domain controllers.

Before installing this update

You must have the following required updates installed before you apply this update. If you use Windows Update, these required updates will be offered automatically as needed.

- You must have the SHA-2 update (KB4474419) that is dated September 23, 2019 or a later SHA-2 update installed and then restart your device before you apply this update. For more information about SHA-2 updates, see 2019 SHA-2 Code Signing Support requirement for Windows and WSUS.
- For Windows Server 2008 R2 SP1, you must have installed the servicing stack update (SSU) (KB4490628) that is dated March 12, 2019. After update KB4490628 is installed, we recommend that you install the latest SSU update. For more information about the latest SSU update, see ADV990001 | Latest Servicing Stack Updates.
- For Windows Server 2008 SP2, you must have installed the servicing stack update (SSU) (KB4493730) that is dated April 9, 2019. After update KB4493730 is installed, we recommend that you install the latest SSU update. For more information about the latest SSU updates, see ADV990001 | Latest Servicing Stack Updates.
- Customers are required to purchase the Extended Security Update (ESU) for on-premises versions of Windows Server 2008 SP2 or Windows Server 2008 R2 SP1 after extended support ended on January 14, 2020. Customers who have purchased the ESU must follow the procedures in KB4522133 to continue receiving security updates. For more information on ESU and which editions are supported, see KB4497181.

Important You must restart your device after you install these required updates.

Install the update

To resolve the security vulnerability, install the Windows updates and enable **Enforcement** mode by following these steps:

1. Deploying the December 8, 2020 updates to all Active Directory domain controllers in the forest.
2. After all Active Directory domain controllers have been updated, wait at least a week to allow all outstanding Service for User to Self (S4U2self) Kerberos service tickets to expire and then full protection can be enabled by deploying Active Directory domain controller **Enforcement** mode.

   Note If you have modified the Kerberos service ticket expiration times from the default settings (default is 7 days), then you must wait at least the number of days as configured in your environment.

Registry Key Change Required After the Patch is Installed

This update introduces the following registry setting to enable **Enforcement** mode.

Registry subkey	HKEY_LOCAL_MACHINE\System \CurrentControlSet\Services\Kdc
Value	PerformTicketSignature
Data type	REG_DWORD
Data	**1**: Enables **Deployment** mode. The fix is enabled on the domain controller, but the Active Directory domain controller does not require that Kerberos service tickets conform to the fix. This mode adds support for ticket signatures on CVE-2020-17049 updated domain controllers but the domain controllers do not require tickets to be signed. This allows a mix of updated and unupdated domain controllers to coexist. With all domain controllers updated and at setting **1**, all new tickets will be signed. In this mode, new tickets will be marked as non-renewable. **2**: Enables **Enforcement** mode This enables the fix in required mode where all domains must be updated and all Active Directory domain controllers require Kerberos service tickets with signatures. With this setting, all tickets must be signed in order to be considered valid. In this mode, tickets will again be marked as renewable. **0**: Not recommended. Disables Kerberos service tickets signatures, and your domains are not protected. **Important:** Setting **0** is not compatible with enforcement setting **2**. Intermittent authentication failures might occur if enforcement mode is applied later stage while domain are set to **0**. We recommend customers to move to setting **1** before the enforcement stage (At least a week before applying enforcement).
Default	**1** (when registry key is not set)
Is a Restart required?	No

Conclusion

The Kerberos Bronze Bit attack takes advantage of Microsoft Kerberos implementation details that provide an attacker with access the ability to request and modify Kerberos service tickets to impersonate any Active Directory user. Since the attack code is now publicly available, attackers can leverage this capability in AD environments today. The patch process involves installing the patch on all Domain Controllers, waiting a week, and then configuring the registry key to enforce the new Kerberos configuration which involves signing all Kerberos tickets to prevent future tampering. Since the update process requires installing the patch and then setting a registry key, it's expected that many environments

will remain vulnerable until Microsoft releases a subsequent patch (planned for February 2021) which sets the new registry key to enforcement by default. Detection of the Kerberos Bronze Bit attack is difficult since the Kerberos ticket used in the attack has common items configured and there is no clear sign of tampering (ticket is encrypted with the service account's password hash).

Trimarc provides leading expertise in security solutions including security reviews, strategy, architecture, and implementation. Our methodology leverages our internal research and custom tooling which better discovers multiple security issues attackers could exploit to compromise the environment. Trimarc security services fit between traditional compliance/audit reviews and standard penetration testing/red teaming engagements, providing deep understanding of Microsoft and Virtualization technologies, typical security issues and misconfigurations, and provide recommendations based on our own best practices custom-tailored to balance operational and security challenges.